

IT POLICY

TESTINGXPERS PRIVATE LIMITED
SITE No. 13-A, RAJIV GANDHI CHANDIGARH I.T PARK, CHANDIGARH

Issue No.	Issue Date	Document No.	Author Name	Author Role	Approver
01	03-December-2018	TXPL/FR/IT/008	Rajnish Batta	Operations	Manish Gupta (CEO)
Revision History					
Revision No.	Date of Release	Section/Page # Changed	Details of Changes	Reviewer	Approver
01	15-Apr-2021	Sections 17.8,19.3	1.Give reference of Patch Management Policy 2. Introduce the point of change management via ticketing tool	Hari Prasad	Manish Gupta (CEO)
02	04-Feb-2022	Updated- 3.1 & 9.6 Removed- 1.18 & 9.5	1.Procedures should be developed for business-critical areas 2.Login system to display last login date and time 3. Change duration of IT workshop 4.System logoff period changed due to inactivity	Hari Prasad	Manish Gupta (CEO)
03	08-Jun-2023	Updated-19.13	Summary report should be presented to higher management once the changes implemented.	Hari Prasad	Manish Gupta (CEO)
04	15-Dec-2023	Updated-8.8	(a)Encryption of file/data. (b)Use of Secure Cloud Services for File- (c)Use of End-to-End Encryption secure tunnel:	Rajnish Batta	Archana Gupta (CFO)
05	27-Apr-2024	Updated-10.2	A password should not be less than 12 characters.	Rajnish Batta	Archana Gupta (CFO)

06	07-Jun-2024	Removed - 9.10 Addition of Section 26	Personnel Exit Access Policy	Rajnish Batta	Archana Gupta (CFO)
07	02-Jun-2025	Additions of: Section 27 Section 28 Section 29 Section 30 Section 31	Cloud Usage Policy Web Filtering Policy Data Masking Policy Data Encryption Policy Data Leakage Prevention Policy	Rajnish Batta	Archana Gupta (CFO)
08	17-Jul-2025	Section 27	Cloud Usage Policy – Sub section 27.10 – Responsibility Matrix Added.	Rajnish Batta	Archana Gupta (CFO)

Contents:

Introduction:	5
1. Corporate Security Policy	5
2. Acceptable Use Policy	6
3. Security Awareness Policy	7
4. Data Protection Policy	7
5. Information Safeguarding Policy	8
6. Virus Control Policy	8
7. Internet Usage Policy	9
8. E-mail Usage Policy	10
9. Login Policy	10
10.Password Protection Policy	11
11.Router and Firewall Security Policy	11
12.Virtual Private Network (VPN) Policy	12
13.Wireless Communication Policy	12
14.General Physical Security Policy	13
15.Computer Room/Data Center Security Policy	13
16.Magnetic Media Policy	14
17.Server Security Policy	14
18.Configuration Management Policy	15
19. Change Management Policy	15
20.Printed Output and Distribution Policy	16
21.General Business Continuity Policy	16
22.Backup and Recovery Policy	17
23.Personnel Policy	17
24.Third Party Policy	17
25.Equipment Safeguard Policy	18
26.Personnel Exit Access Policy	19
27.Cloud Usage Policy	20
28.Web Filtering Policy	22
29.Data Masking Policy	24

30.Data Encryption Policy	25
31.Data Leakage Prevention Policy	26

IT POLICY

Introduction:

At TestingXperts “Tx” (including its companies globally, together the “Company”), information is important and protecting this information is critical for our business’s survival. In order to safeguard this intellectual asset, an Information Security Policy is an absolute must. We are publishing this Information Security Policy Manual, which covers key areas of concern related to information security. This policy is for the awareness of all employees that Information Security is everyone’s responsibility and that everyone is required to learn about Information Security and to attend events concerning the same.

This Information Security Policy is divided into different areas: Data Ownership, Antivirus and Malicious Programs, Internet-related Policies, Access Control, Network Policies, Physical Security, Operations Management, Business Continuity Policy and Personnel & Third-Party policies.

A System Administrator will co-ordinate and supervise the implementation of all security policies.

1. Corporate Security Policy

A. Purpose

The purpose of the Corporate Security Policy is to specify requirements and set direction for the organization's security from the high-level perspective of senior management.

B. Scope

The prime audience of this policy is department managers, while the secondary audience is all other employees of the organization.

C. Policy

- 1.1 Information security is everyone's responsibility.
- 1.2 All access to corporate resources and information should be on a 'Need to Know' basis.
- 1.3 A System Administrator will coordinate the implementation of all security policies. At a later stage an “Information Security Forum” may be formed, if required.
- 1.4 Information should be protected in terms of Confidentiality, Integrity, and Availability (CIA) when it is stored, processed, or transmitted, regardless of the storage medium and mode of transmission.
- 1.5 All of the organization’s critical assets (e.g. hardware, software, equipment, and data) should be identified and appropriately protected.
- 1.6 A formal Inventory of all assets should be compiled. All Assets and Information should be appropriately classified and labeled as per the business's requirements.
- 1.7 Resource rights which are not explicitly assigned should be assumed to be denied.
- 1.8 When information is transmitted outside the organization, special measures should be taken to secure it.
- 1.9 The organization reserves the right to monitor information traffic and all Communications regardless of the medium being used.
- 1.10 The perimeter network should be appropriately protected with proper hardware and software.
- 1.11 Proper monitoring of the perimeter network and internal network should be done on a regular basis.
- 1.12 To provide protection against common threats to the organization, appropriate safeguards should be in place, including anti-virus programs and firewalls.
- 1.13 Regular checks on network, servers and other equipment should be conducted in order to make sure that the network is properly secure.
- 1.14 All information abuses and security breaches should be reported to the System Administrator.
- 1.15 Business Continuity of the organization should be ensured with proper measures.
- 1.16 Proper Security Awareness programs should be organized by the System Administrator.

- 1.17 The organization resources should be used for management-approved purposes only.
- 1.18 Prime importance should be given to physical security.
- 1.19 The Information Security document should be reviewed on a quarterly basis.
- 1.20 Disciplinary action, ranging from verbal reprimand to termination of employment, depending on the severity of the violation, may be taken.
- 1.21 Proper procedures for "Incident Handling" should be in place.
- 1.22 All security incidents, weaknesses, and malfunctions should be reported to the System Administrator. The System Administrator will ensure that the issue is addressed and will devise a mechanism to prevent recurrence in the future.
- 1.23 The proper skills should be developed to address any security-related incidents.
- 1.24 Proper checking for vulnerability with the help of a Penetration test should be carried out on a regular basis.
- 1.25 All systems, especially the operating systems, should be hardened to an acceptable level.
- 1.26 Physical security is of prime importance. All efforts should be made to secure the physical perimeter, physical entry points, office rooms, and delivery/loading areas.
- 1.27 Proper measures should be taken for securing all equipment, power supplies, and cables.
- 1.28 Security of equipment while being maintained off-premises should be assured.
- 1.29 All employees should wear their identity badges when on the company premises.
- 1.30 Discussion of company business information in public places such as elevators or cafés is strictly prohibited.
- 1.31 At the end of a meeting, all whiteboards should be cleaned, and flip-chart paper removed.
- 1.32 A 'Clean Desk' policy should be observed throughout the organization.
- 1.33 No games should be stored or played on company computers.
- 1.34 All advertisements for jobs and help should be reviewed thoroughly and should not disclose any sensitive information or future company plans.
- 1.35 If a company employee is presenting a paper, giving a presentation, or delivering a speech in a public forum or conference, all material must be reviewed by his/her immediate manager prior to presentation.
- 1.36 An annual Audit of the system should be performed to check the control of the systems.
- 1.37 All documentation in the company should have a version control page with the document's history. All pages should be numbered.
- 1.38 Disciplinary action will be taken for non-compliance with a security policy.
- 1.39 A proper Business Impact Analysis and Risk Assessment should be performed for all critical business systems, either by the Department Heads or by an outsourced resource.
- 1.40 In the case where 'Specialist Advice' is required, an outside consulting company may be approached for help.
- 1.41 The organization should comply with all the legal requirements as specified by the government of the country. Employees shall not indulge in an activity that is illegal under local or international law.

D. Enforcement

In the case of a policy violation, disciplinary action will be taken which may include the termination of employment.

E. Responsibility

All employees, Departmental Managers and the System Administrator.

2. Acceptable Use Policy

A. Purpose

The purpose of the Acceptable Use Policy of TestingXperts is to communicate the acceptable behavior of the employee which is necessary to ensure the Confidentiality, Availability, and Integrity (CIA) of the systems, assets and information.

B. Scope

The scope of this policy covers all permanent/contract employees, consultants, and vendor/third parties' assigned persons working for the organization.

C. Policy

- 2.1 Security is everyone's responsibility every day. All employees of TestingXperts should follow the security policies applicable to their area.

- 2.2 Organization resources are meant for business use and should be used for business purposes only.
- 2.3 From time to time the organization's management will be issuing guidelines that need to be followed.
- 2.4 An excuse of unawareness of a security policy will not be acceptable.
- 2.5 All of the information stored on or transmitted over the organization's resources remains the organization's property and the organization has the right to monitor and audit them.
- 2.6 All of the organization's confidential information should be treated in strict confidence. Copying or transmitting of the information is strictly prohibited except when required for organization business.
- 2.7 It is the employee's responsibility to protect all of the passwords and pass phrases assigned to them. They should not share these with any other person.
- 2.8 A password should be changed as per the password policy.
- 2.9 All sensitive information stored in a laptop and desktop should be password protected.
- 2.10 All machines should run the latest antivirus software. No employee is allowed to disable or deactivate the virus detection engine.
- 2.11 No unauthorized copying of software is allowed.
- 2.12 No organizational resources should be used to test software as it may malfunction or be malicious in nature. An exception is made for software that is to be used in the organization.

D. Enforcement

In the case of a policy violation, disciplinary action will be taken which may include the termination of employment.

E. Responsibility

All employees.

3. Security Awareness Policy

A. Purpose

The purpose of this policy is to keep employees up to date with information security, which is changing at an astonishing pace.

B. Scope

The policy applies to all employees, no matter what position they hold.

C. Policy

- 3.1 The System Administrator will organize IT workshops on a half-yearly basis for employees and the attendance of every employee will be mandatory.
- 3.2 In the case where an employee has not attended the workshop, his/her respective manager will be informed.
- 3.3 If necessary, the System Administrator takes help of brochures, Posters and/or special Security Awareness Screen Saver to increase Information Security.
- 3.4 It is the responsibility of every individual to keep him/herself up to date through involvement in security program training as conducted by the organization.
- 3.5 Any security breach or query about security should be communicated to the System Administrator immediately.
- 3.6 Knowledge of security policies is one of the areas that will be assessed during appraisal of the employee.

D. Enforcement

In case of a policy violation, disciplinary action will be taken which may include the termination of employment.

E. Responsibility

All employees, especially the System Administrator and IT manager.

4. Data Protection Policy

A. Purpose

The purpose of the policy is to implement proper data ownership for Information Security. The owner of the data needs to be clearly specified with corresponding duties and responsibilities.

B. Scope

The policy applies to all employees who at any time are responsible for data handling, using and owning.

C. Policy

- 4.1 The Data Owner should be specified for each application. The Data Owner is the person who heads or leads the business unit. For example, the finance department manager owns finance data, not the IT Department. IT is merely the "Data Custodian" or the "Data Trustee".
- 4.2 The Data Owner will communicate the importance of the data, level of sensitivity, controls and monitoring requirements to the Data Custodian.
- 4.3 The Data Custodian may not take any action on the data without the permission of the Data Owner.
- 4.4 It is the responsibility of the Data Owner to ensure that data is backed up and stored on a shared drive with user access permission.
- 4.5 The Data Custodian will make sure that there are proper safeguards in place to recover from any Disaster.
- 4.6 Any data which is not on the server or is not backed up by the corporate backup facility, e.g. laptop or workstation data, will be the responsibility of the end-user to make sure that recovery is possible in the case of system failure or hard disk crash.
- 4.7 The Data Custodian will make sure that all adequate controls are in place, as specified by the Data Owner.
- 4.8 The Data Custodian should maintain proper documentation of all activities involving the Owner's data.
- 4.9 The Data Custodian will inform the Data Owner of any risk or shortcomings as soon as they are identified.

D. Enforcement

In the case of a policy violation, disciplinary action will be taken which may include the termination of employment.

E. Responsibility

Data Owner, Data Custodians, Department Heads and System Administrator.

5. Information Safeguarding Policy

A. Purpose

This policy specifies the control and proper safeguard of information generated, stored and transmitted in the organization.

B. Scope

The policy applies to all forms of information regardless of what medium is used for their storage and communication.

C. Policy

- 5.1 The Data owner will decide about the frequency of their data being backed up based on the project requirement, on the basis of importance and retention period of the information. The data lost should not be more than 24 hours.
- 5.2 Corporate Server backup frequency and retention should be defined and implemented by coordination of data owner and System Administrator.
- 5.3 All backups should be verified to ensure that it is re-storable.
- 5.4 Off-site backup of data and applications on critical machines is highly recommended and should be carried out at least weekly.
- 5.5 The Data Owner should specify the data retention period.
- 5.6 No pirated or other illegal software may be used in the organization.
- 5.7 Any software is to be bought only after proper permission from the department head and to be installed by the System Administrator.
- 5.8 Proper measures such as the installation of anti-virus software, firewalls, Penetration test (half yearly) should be taken to address external and internal threats.

D. Enforcement

In the case of a policy violation, disciplinary action will be taken which may include the termination of employment.

E. Responsibility

All employees, Department Heads and System Administrator.

6. Virus Control Policy

A. Purpose

This document specifies the organization's policy related to malicious programs i.e. Viruses, Worms, Trojans and others.

B. Scope

The scope of the policy includes all electronic communication mediums as well as all storage media which can be infected or can store or propagate malicious programs.

C. Policy

- 6.1 All machines should run the latest anti-virus software as approved by organization management.
- 6.2 E-mail with attachments coming from suspicious or unknown sources should not be opened. All such e-mails and their attachments should be deleted from the mail system as well as from the trash bin. No one should forward any e-mail which a/he thinks may contain virus.
- 6.3 All removable media should be blocked for use or scanned for viruses before being used.
- 6.4 No pirated software should be used on the corporate network.
- 6.5 In the case of a virus being found, the System Administrator should be informed immediately. The System Administrator will investigate and take proper measures to avoid the event in future.
- 6.6 No user should clean a virus from a computer
- 6.7 All encrypted material should be decrypted and checked for viruses before being used.
- 6.8 The e-mail Server should have the antivirus program installed and must check all of the e-mail attachments before sending it to individual mailbox.
- 6.9 All of the updates to the antivirus program should be automatic from the web or from the central server
- 6.10 Antivirus Program should be supplemented by following components:
 - Personal Firewall
 - Network Attack Blocking
 - Capacity Management

D. Enforcement

In the case of a violation of the security policy, disciplinary action will be taken, up to and including employment termination.

E. Responsibility

All employees and System Administrator.

7. Internet Usage Policy

A. Purpose

This document specifies the organization policy related to cyber-surfing and Internet Usage.

B. Scope

The scope of the policy includes all employees, irrespective of their position.

C. Policy

- 7.1 Only official Internet connections should be used.
- 7.2 Internet facilities will be provided to employees for business use only. No Internet usage for personal purposes is allowed.
- 7.3 While using the Internet, no person is allowed to abuse, defame, stalk, harass or threaten any other person, or violate local or international legal rights.
- 7.4 No person is allowed to upload, post, publish or distribute any inappropriate, indecent, obscene, profane, infringing, defamatory or unlawful information or material on the Internet while using the corporate resources.
- 7.5 No person is allowed to post personal advertisements or offer any goods or services using the organization's resources.
- 7.6 In case of access of websites, there are predefined categories with specific permissions and assign user to specific access category with manager's approval

Category	Access Type
Full Access	All Websites Access
YouTube Access	YouTube + Restricted Access
Social Sites Access	All Social Sites + Restricted Access
Restricted Access	Search only websites with minimal permissions
- 7.7 A visit to any obscene sites or sites which are non-business related will be considered a serious offence.

D. Enforcement

In the case of a violation of the security policy disciplinary action will be taken, up to and including employment termination.

E. Responsibility

All employees, System Administrator.

8. E-mail Usage Policy**A. Purpose**

This document specifies the organization policy related to e-mail usage, including the receiving, replying, forwarding and auto reply functions.

B. Scope

The scope of the policy includes all permanent and contract employees irrespective of their position in the organization.

C. Policy

- 8.1** The e-mail facility is for business use only. The e-mail address allocated to an employee should not be used for personal purposes.
- 8.2** No free e-mail facility should be used to receive or send business-related information.
- 8.3** No non-business-related newsgroup may be added to your organization's e-mail address book.
- 8.4** The e-mail facility of the organization should not be used to spam other users, whether they are inside or outside the organization.
- 8.5** No harassing or insulting messages should be sent inside or outside of the organization.
- 8.6** No person is allowed to forward chain letters or pyramid schemes using corporate e-mail.
- 8.7** No confidential document belonging to the organization may be sent to anyone, including to your own personal free-mail account.
- 8.8** If sensitive information needs to be sent to someone outside the organization, proper measures should be taken as specified by the System Administrator.
 - a. Encryption of file/data, this helps in limiting the shared data access to those who have the encryption key.
 - b. Use of Secure Cloud Services for File-Sharing (Microsoft OneDrive) It ensures the data is shared safely and securely to intended recipient by entering the email address of that user & prevents sending files to unauthorized users.
 - c. Use of End-to-End Encryption secure tunnel: sharing the data to client/outside through secure VPN tunnels.
- 8.9** The organization's e-mail address can be used when posting to business-related newsgroups provided permission is obtained from the respective manager.
- 8.10** An e-mail program such as Outlook should not be running when employees leave at the end of the workday, as hackers may misuse it.

D. Enforcement

In the case of a violation of the security policy, disciplinary action will be taken, up to and including employment termination.

E. Responsibility

All employees, Departmental Managers and System Administrator.

9. Login Policy**A. Purpose**

This document specifies the organization policy relating to login to critical machines and it discusses in detail the related standards.

B. Scope

The scope of the policy includes all logins to critical applications and servers, irrespective of their operating platforms.

C. Policy

- 9.1** Every user should have a uniquely assigned login name and password to access corporate computer systems.
- 9.2** Each person is responsible for the login name assigned to him/her
- 9.3** A password should not be displayed on the screen.
- 9.4** In the case where an incorrect login name or password is entered, no response which reveals any information should be given. For example, systems should not respond with "Incorrect Password for xxx login name". This message will reveal that such a valid username exists leaving the attacker having only to crack the password.

- 9.5 The system should log-off (lock) automatically after inactivity of 15 minutes or a period specified by the System Administrator.
- 9.6 In the case where a job function is based on a general USER ID, the USER ID should be changed to a unique one.
- 9.7 Time-based access should be implemented for the user login, where possible.
- 9.8 All login names and privileges should be reviewed at regular intervals in close co-operation with the Human Resources functions.
- 9.9 A login which is not successful should be logged and the log reviewed at regular intervals.
- 9.10 A login ID not used for 90 days will be disabled and later deleted with the permission of the employee's Department Manager.

D. Enforcement

In the case of a violation of the security policy, disciplinary action would be taken, up to and including employment termination.

E. Responsibility

All employees, Departmental Managers and the System Administrator.

10. Password Protection Policy

A. Purpose

This document specifies the organization policy related to password protection, change and maintenance.

B. Scope

The scope of the policy includes all employees, irrespective of their position.

C. Policy

10.1 All default passwords should be changed by the user prior to use of the system.

10.2 Password strength should at least be 12 characters long, made up of a mixture of alphabetic (upper case and lowercase), numeric and alpha numeric characters/symbols.

10.3 A password should be changed every 45 days or whenever compromised.

10.4 No common name or personal information should be used as a password e.g. date of birth, spouse's name, pet name or phone number.

10.5 A password should be different from the last 3 passwords.

10.6 A password should always be kept secret and should never be disclosed to co-workers and colleagues.

10.7 All PCs should have the login password enabled.

10.8 No person should leave his/her PC or terminal without logging off or password protecting the screen.

10.9 The initial password is given by the System Administrator which is changed by the user to login to the system.

D. Enforcement

In the case of a policy violation, disciplinary action will be taken which may include the termination of employment.

E. Responsibility

All employees, Departmental Managers

11. Router and Firewall Security Policy

A. Purpose

Network Routers and Firewalls are the most vulnerable components of network security. This document provides the minimum-security protection for the routers and firewalls.

B. Scope

The scope covers the firewall and routers of the network.

C. Policy

11.1 Routers and firewalls should be placed in a physically secure area.

11.2 Local User Accounts should not be configured on the router. The firewall management terminal should be separate from the main box.

11.3 The password for routers and firewalls should match the restrictions of Password Policy.

11.4 The Firewall should be a dedicated machine. It should not be used to run any services other than related to firewall and protection.

11.5 Routers and firewalls should disallow all invalid IP addresses coming from the Internet

11.6 Routers and firewalls should not allow IP broadcasts.

11.7 The firewall should be configured to stop SYN attack.

11.8 Firewall should stop IP spoofing, fragmented packets, and teardrop.

11.9 The relevant Department Manager should approve the list of Access rules prior to deployment of routers.

11.10 The backup of the configuration files of the firewall and routers should be stored at a safe place.

11.11 The firewall must hide all internal network addresses from the outside world.

D. Enforcement

In the case of a policy violation, disciplinary action will be taken which may include the termination of employment.

E. Responsibility

Network administrator, Firewall administrator

12. Virtual Private Network (VPN) Policy

A. Purpose

The purpose of the VPN policy is to provide guidelines for secure remote access to the local networks.

B. Scope

The VPN policy applies to connections to the organization and to third parties including consultants, vendors and contractors.

C. Policy

12.1 As VPN is an extension of the corporate network, all of the security rules apply to the remote client as if they were within the organization.

12.2 All critical connections to the outside should use the safe channel. Corporate choice is to use SSL for VPN, where available.

12.3 It is highly recommended that a one-time password be used.

12.4 "Tunnel Mode" is preferred whenever the VPN is used. If performance is an issue, "Transport Mode" may be used. with the permission of the System Administrator.

12.5 All files transferred through VPNs should be subject to antivirus scanning.

12.6 The VPN timeout period is 300 seconds of inactivity.

D. Enforcement

Any Policy Violation will be subject to disciplinary action, which may go so far as employment termination.

E. Responsibility

Network administrator, VPN user and the System Administrator.

13. Wireless Communication Policy

A. Purpose

The Purpose of the policy is to provide guidelines for network connections via wireless communication.

B. Scope

The policy covers all wireless devices such as mobile phones, PDA and laptop computers and others, which are connected to the organization corporate network.

C. Policy

13.1 The System Administrator should approve all wireless devices connected to the corporate network.

13.2 A Wi-Fi Controller should be used to grant permission to the wireless devices.

13.3 Prior to the granting of a connection to the network devices, it would be preferable that the Wi-Fi controller verify the hardware level address check the MAC address.

D. Enforcement

Any Policy Violation will be subject to disciplinary action, which may go so far as employment termination.

E. Responsibilities

Equipment user and the System Administrator.

14. General Physical Security Policy

A. Purpose

This policy specifies the requirements for physical security. No matter how good the security solutions and products are, if physical security is weak, everything can be compromised.

B. Scope

This policy is applicable to all physical areas of the office/s of the organization, including those available now and those which may be added in the future.

C. Policy

14.1 The Operations Manager should define security zones within the organization. For example:

- i. Zone A: The reception area where anyone can walk in (Minimum Security).
- ii. Zone B: Area accessible to employees and authorized visitors
- iii. Zone C: Area to which only selected employees have access such as the Computer room and other business-critical areas.

14.2 The Operations Manager should apply appropriate measures for each of the zones.

14.3 Office floor plans and diagrams of telephone, electrical, water and network cabling lines, as well as extinguisher locations should be documented and maintained.

14.4 A proper Access Control List with corresponding work times should be maintained.

14.5 The entrance of the organization should be properly guarded.

14.6 Proper fire prevention and detection mechanisms should be in place.

14.7 A Telephone Directory for emergency phone numbers should be maintained and must be easily accessible.

14.8 A First Aid Box should be provided and must be easily accessible and regularly checked and replenished.

14.9 All areas of the office should be properly lighted

D. Enforcement

A Policy Violation will be subject to disciplinary action, which may go so far as employment termination.

E. Responsibilities

Operations & HR Department/representative.

15. Computer Room/Data Center Security Policy

A. Purpose

This policy discusses the requirements for safeguarding the computer systems and personnel operating in the computer room/data center.

B. Scope

This policy is applicable to all physical areas of the office/s of the organization, including those which are available now and those which may be added in the future.

C. Policy

15.1 Access to the computer room will be restricted to organization authorized persons only.

15.2 No public visits or tours of the computer room are allowed.

15.3 Vendor and third-party representatives, if they visit the room, should be escorted.

15.4 A proper fire alarm and fire extinguisher system should be in place.

15.5 A proper temperature should be maintained and monitored.

15.6 A proper Emergency procedure for the computer room should be developed and be easily accessible. Personnel should be trained so that the procedure is executed efficiently, when required. All procedures should be audited at regular intervals.
(To make Emergency Procedure document)

15.7 The System Administrator will co-ordinate the development of computer room standards.

15.8 The System Administrator will co-ordinate measures to ensure that a reliable power supply to the computer room is in place and that adequate safeguards are there to protect the equipment.

15.9 No drinking, eating or smoking is allowed in the computer room.

15.10 Use of a cellular phone is prohibited in the data center.

D. Enforcement

A Policy Violation will be subject to disciplinary action, which may go so far as employment termination.

E. Responsibilities

System Administrator.

16. Magnetic Media Policy

A. Purpose

This policy discusses the requirements for the handling of Magnetic media.

B. Scope

This policy is applicable to all media, i.e. Hard Disk, Compact Disc, Floppy Disk, Laser Disk, Super Floppy, Magnetic Tape Reel, Magneto-Optical Disk, Zip Disk, Magnetic Tape Cartridge and Digital Audio Tape

C. Policy

16.1 An inventory of all critical magnetic media should be maintained and kept in the secure magnetic media library.

16.2 All magnetic media should be properly labeled.

16.3 All magnetic media should be physically destroyed prior to discarding.

16.4 All media should be scanned for viruses prior to use.

D. Enforcement

A Policy Violation will be subject to disciplinary action, which may go so far as employment termination.

E. Responsibilities

System Administrator.

17. Server Security Policy

A. Purpose

This security policy discusses the issue of securing the internal servers of the organization. This is to make sure that there is no unauthorized access to corporate information.

B. Scope

This policy applies to all servers either owned or operated by the organization.

C. Policy

17.1 The Server should be in a physically secure place.

17.2 All configuration of the servers should be documented and approved by the IT Manager and System Administrator.

17.3 Each server should have documentation of configuration, operating system version, patches installed, backup and recovery procedure.

17.4 All Change Management Policies should be strictly implemented on the servers.

17.5 The System Administrator should approve all configuration of servers.

17.6 Services not required, such as the web server and others, should be disabled.

17.7 The Log of the server should be monitored on a regular basis, as specified by the System Administrator.

17.8 All security patches should be installed on the server after confirmation that they will not have any adverse effect on the running applications.

17.9 All guests and default accounts will be either disabled or their password changed.

17.10 If remote management of the server is required, a secure channel should be used for this purpose.

17.11 The privileged account like super user and root should only be used when required.

17.12 A regular Audit would be performed by the System Administrator

D. Enforcement

A Policy Violation will be subject to disciplinary action, which may go so far as employment termination.

E. Responsibilities

System Administrators, System Administrator and IT Manager.

18. Configuration Management Policy

A. Purpose

This security policy deals with proper documentation for the configuration of critical systems.

B. Scope

This policy applies to all servers, network equipment and others, either owned or operated by the organization.

C. Policy

18.1 All system configurations, including hardware, software and core business software, should be documented.

18.2 There should be a hard copy and a soft copy of the documentation.

18.3 Configuration Management should be considered as the documentation baseline. All changes from this baseline should be documented as per the Change Management Policy.

18.4 Prior to roll out, any modification made to the default configuration should be documented in the configuration management documentation.

18.5 IT Manager should approve all configuration documentation. Please refer to the supporting Configuration Items Inventory document (TXPL/FR/IT/032).

18.6 Configuration management and change management documentation should be used together, in case of recovery.

D. Enforcement

A Policy violation will be subject to disciplinary action, which may go so far as employment termination.

E. Responsibilities

System Administrators, System Administrator and IT Manager.

19. Change Management Policy

A. Purpose

This security policy sets out the proper change management documentation for all critical systems.

B. Scope

This policy applies to all critical servers, network equipment and business-critical software owned or operated by the organization.

C. Policy

19.1 Standardized methods and procedures should be used for the efficient and prompt handling of the changes and revision control.

19.2 All changes should be documented, and prior approval must be obtained for all changes made to critical production systems.

19.3 A "Change Request" should be presented to the relevant manager for approval. The System Administrator will co-ordinate the workflow for change approval.

19.4 All requested changes should be evaluated and have their impact assessed before approval or disapproval.

19.5 All changes, once approved, should be scheduled in such a way as to ensure the availability of a time slot for a rollback, should something unexpected happen.

19.6 Documentation for a change request should be accompanied by detailed, step-by-step procedures to do the change. It should also include detailed rollback procedure, in case the change fails, and the desired result is not achieved.

19.7 Whenever there is a need to change the application software, system software, LAN or any hardware, the change should be appropriately authorized and approved.

19.8 Every change should be thoroughly tested and fully documented.

19.9 Changes should be made when there is minimum or no activity on the system. In cases where there is more than one change to be carried out at a given time, the changes should be queued on the basis of business and technical priority.

19.10 Changes should only be approved after adequate consideration of the associated impact and implications.

19.11 Changes, once accepted, should be entered into the Change Management log.

19.12 The Change should be fully tested, and the result presented to the respective manager.

19.13 A Change Management Summary report should be presented to higher management once the changes are implemented.

D. Enforcement

A Policy violation will be subject to disciplinary action, which may go so far as employment termination.

E. Responsibilities

System Administrator.

20. Printed Output and Distribution Policy

A. Purpose

This security policy sets out the requirements for printed output and its distribution.

B. Scope

This policy applies to all critical servers, network equipment and business-critical software owned or operated by the organization.

C. Policy

20.1 The System Administrator will ensure that a procedure exists that ensures that the report goes only to the authorized individual.

20.2 The person who prints the report is responsible for ensuring the proper protection of the information it contains.

20.3 Should someone find a report that is classified and is not intended for him/her, s/he should inform the System Administrator.

D. Enforcement

A Policy violation will be subject to disciplinary action, which may go so far as employment termination.

E. Responsibilities

Report Printing User, System Administrator

21. General Business Continuity Policy

A. Purpose

The purpose of this policy is to provide directions regarding business continuity.

B. Scope

This policy applies to all business-critical systems as referred to in the Business Impact Analysis and Risk Assessment in the Corporate Security Policy.

C. Policy

21.1 The System Administrator will ensure that the availability of the business-critical system is ensured as per the Risk Assessment requirement of the Corporate Policy.

21.2 Depending on the Risk Assessment report (as per the Corporate Security Policy), Senior Management will decide the scope of the recovery plan.

21.3 Crucial systems, as per the risk assessment, should have reliable recovery procedures in case of disaster.

21.4 The word "Disaster" needs to be defined, and the respective risk evaluated by senior management. The System Administrator should coordinate this task.

21.5 All documentation related to business continuity should be regularly updated.

21.6 The Information Security Manager will ensure that there is an appropriate Contingency plan, and "Emergency Response Plan" are in place.

D. Enforcement

A Policy violation will be subject to disciplinary action, which may go so far as employment termination.

E. Responsibilities

Business Department Heads, System Administrator, and IT Manager.

22. Backup and Recovery Policy

A. Purpose

This security policy specifies the backup and recovery standards for the organization.

B. Scope

This policy applies to all critical servers such as database servers, application servers and network equipment such as firewall's configuration owned or operated by the organization.

C. Policy

22.1 Backup of all critical devices including servers and network equipment should be undertaken.

22.2 Frequency of the backup will be decided according to the nature of the application being used.

22.3 The backup method to follow is "Full Backup" followed by "Incremental backup".

22.4 The timing of "Distributed Backups" should be planned to have the minimum impact on the corporate network.

22.5 The backup process should not violate the confidentiality of the system.

22.6 No public computers should be used for backing up sensitive data.

22.7 All archive data must be tested on a regular basis.

22.8 All backups should be verified to check the validity of the media.

22.9 A copy of critical data should be stored in a remote location.

22.10 A remote location can be a branch office of the organization located in a different city /country.

22.11 The data stored in a different location should be used in case of disaster occurring at the site level.

22.12 Once the backup media is no longer usable, it should be physically destroyed or preferably burnt.

D. Enforcement

A Policy violation will be subject to disciplinary action, which may go so far as employment termination.

E. Responsibilities

All employees, System Administrator and IT Manager.

23. Personnel Policy

A. Purpose

This security policy specifies guidelines and standards related to Human Resource (HR) with special reference to Information Security.

B. Scope

This policy applies to all permanent and contract employees.

C. Policy

23.1 Prior to hiring a prospective employee, HR must do a background check, contact references and validate the education testimonial.

23.2 Employees should sign the undertaking accepting responsibility for adherence to security policies.

23.3 HR will ensure that security responsibility is included in the job responsibilities of the employee.

23.4 The Terms and Conditions of employment shall mention the Information Security policy for each employee.

23.5 HR will ensure that segregation of duties and job rotation is implemented, where possible.

23.6 When an employee leaves the employment of the company, HR will ensure that an exit interview is conducted.

23.7 HR will ensure that the person has all computer accounts removed prior to his/her final settlement.

23.8 In the case where employment is terminated without the consent of the employee, he/she should be escorted from the premises.

D. Enforcement

A Policy Violation will be subject to disciplinary action, which may go so far as employment termination.

E. Responsibilities

HR, System Administrator and Department and IT Manager.

24. Third Party Policy

A. Purpose

This security policy specifies the standard and guidelines for third party and outsourcing.

B. Scope

This policy applies to parties whether they are vendors, contractors, consultants, or outsourced professionals.

C. Policy

24.1 The Risks associated with third party involvement and outsourcing should be identified and appropriate measures taken to address them.

24.2 A non-disclosure agreement is essential before sensitive information is shared with a third party.

24.3 The role and responsibilities of the third party should be clearly defined.

24.4 Third party access to the corporate computer system will be given only after the signing of a formal contract which should contain all security requirements by which the third party is to abide.

24.5 All Third party and external users, if defined on the system, should have a mandatory expiry date.

24.6 Third party or outsourced tasks which require dial-in and dial-up privileges, should be restricted and monitored.

D. Enforcement

A Policy violation will be subject to disciplinary action, which may go so far as employment termination. For third party it may lead to contract termination.

E. Responsibilities

Department Heads, HR, System Administrator and IT Manager.

25. Equipment Safeguard Policy

A. Purpose

To ensure maximum safekeeping of the Company's Laptop/Devices and Data.

B. Scope

This policy applies to all permanent and contract employees to ensure before their scheduled travel date to include the following equipment and data security safeguards to their travel planning routines.

C. Policy

25.1 Leave your data and/or device at home. The best way to safeguard your data or device is to not bring them on the trip. If you don't need to access data stored on your laptop/device leave your laptop/device in a secure location at home or deposit it back with the company.

25.2 Backup your data. In the case of travelling with laptop/device, the employees should always take backup of their data. In case the employee loses the data along with the device or some malware corrupts the data during the trip, the employee is sure of having a good copy from which the data can be recovered.

25.3 Configure device. The following requirements are critical for foreign travel:

25.3(1) install and update anti-malware software

25.3(2) choose strong passwords

25.4 Do NOT leave your device unattended. Physically having control of your device is the easiest way for someone to access your data. Do not leave your device unattended, lend it to someone you just met or leave it in your checked bag on your flight. If you ever leave your computer, make sure to turn it off instead of just hibernating it or putting it to sleep.

25.5 Do NOT enter your credentials into public computers. Public computers such as hotel business center workstations and internet cafe computers are often poorly managed and provide minimal security protection for its users. If the need to use public computers arises during your travel, avoid entering your credentials at these public computers.

25.6 Connect only to known wifi networks. It's tempting to stay in touch with friends and colleagues as you travel by connecting to wifi networks. However, anyone can create a network and give the network a legitimate sounding name, hoping to lure unsuspecting travelers to connect while capturing personal information transmitted through the network. This is especially prevalent at public cafes, hotel lobbies and airports. When connecting to a network, find out the correct network name from the staff at the business and connect to it.

25.7 Turn off your wifi when not in use. Attackers can easily spoof Wifi network names to connect to devices within range for eavesdropping. To help you avoid accidentally connecting your device to rogue wifi networks at a later time, once you are finished using the network, turn off wifi on your device.

- 25.8** Practice safe web browsing. The websites you visit online hold valuable data about you. They are also becoming gateways through which hackers can steal your data by infecting reputable or seemingly reputable websites with malware. This threat is magnified during foreign travel as you connect to public networks in hotels, airports, cafes, etc. at your destination.
- 25.9** Do not click on suspicious links or prompts. Malicious websites commonly craft attacks to exploit a user's curiosity, impatience or to scare them with malware threats. These malicious attacks might come in the form of links or pop-ups that present free offers too good to be true or imminent malware infection if you don't install the product. Think before you click a link or "Yes" to a prompt.
- 25.10** Clear browsing session information when using devices that do not belong to you. Some web applications do not log you out entirely, even when clicking the logout button or closing the browser. Such behavior allows the next person who uses the device to browse to the same page or click the back button to access your data as if you are still login. To prevent others from accessing your account and data, clear all the web browser session information.
- 25.11** Take note of credentials you are using during the trip. Regardless of whether you are using them on your device or public computer, they may be compromised. To be safe, take note of the credentials you used so you can change them on a trusted and secure device once you return. Employees need to be mindful that all equipment's which they use or has been issued to them to perform their jobs is owned by TestingXperts. It is the individual responsibility of all employees to care for and safeguard the equipment issued to them and keep it in as close as new condition as possible.
- 25.12** It is the responsibility of the employee to notify the company immediately of loss/damage/theft of the item(s), as to the occurrence and/or explanation thereto. If the item(s) have been stolen, the company also requires the employee to complete an Affidavit at their nearest Police Station immediately and forward the original docket to the company.
- 25.13** The company may deduct from the employee the cost of equipment lost/stolen within a reasonable time, if the employee committed theft or was negligently responsible for the loss.

D. Enforcement

A Policy violation will be subject to disciplinary action, which may go so far as employment termination. For a third party it may lead to contract termination.

E. Responsibilities

Department Heads, HR, System Administrator and IT Manager.

26. Personnel Exit Access Policy

A. Purpose

This document specifies the organization policy relating to employees separating from the company and the non-reporting employees who have access to the corporate system, and it discusses in detail the related standards with process to be followed.

B. Scope

The scope of this policy includes all employees' and contractors' (henceforth, referred to Tx employees) logins, access revocation to corporate systems, example: applications, servers and client systems.

C. Policy

- 26.1** Managers/Head of Department are responsible for notifying the IT team to disable the credentials and access of an employee separating from the company at least 48 hours before the employee's last working day in the organization.
- 26.2** Managers/ Head of Department are responsible for notifying the IT Team for retrieval of any corporate assets (Laptop, Mobile Phone etc.) and client assets.
- 26.3** Upon termination of employment or a new third-party contractor engagement, the IT team should be immediately informed either by the HR Department or the concerned Department Head.
- 26.4** All access rights to the organization's systems, networks, and data shall be revoked immediately upon the employee's exit from the organization. Once access is revoked, no exit employee or contractor can access the organization's systems, networks, or data.
- 26.5** The Delivery Manager is responsible for the particular project or engagement with the respective client and to inform the client about the employee's exit.

- 26.6** The Delivery Manager will ensure that all client-specific access and credentials associated with the departing employee are revoked and confirm the completion of this process to the client.
- 26.7** Revocation of access to an application that is not managed by the IT Team must be raised as a separate request with the application asset owner.
- 26.8** In case of an Account Extension request from the Manager, it must be raised via Helpdesk portal with the approval from Department Head and the following details need to be furnished:
- Purpose of extension
 - Duration
 - Project
- 26.9** The extension of domain account/System login & email account should not exceed more than 30 days.
- 26.10** Extension to backup/SharePoint folders should not be more than 90 days.
- 26.11** If the backup of any data is not requested by the Delivery Manager or Department Head, the IT team would consider it as least important and will wipe the exit user data.
- 26.12** HR or Department Heads must inform Operations team for disabling the access to Work area.
- D. Enforcement**
A Policy violation will be subject to disciplinary action, which may go so far as employment termination.
- E. Responsibilities**
Department Heads, HR, System Administrator and IT Manager.

27. Cloud Usage Policy

A. Purpose

This policy establishes the framework for the secure selection, acquisition, use, and exit from cloud computing services. It ensures that all cloud services align with the organization's information security objectives and manage risks associated with cloud computing.

B. Scope

This policy applies to all employees, contractors, and third-party users involved in the use of cloud services for business purposes across the organization. It supports compliance with applicable legal, regulatory, and contractual requirements.

C. Policy

27.1 Selection of Cloud Services

- Risk Assessment:** Conduct information security risk assessment as per ISMS Standards before selecting any cloud service.
- Due Diligence:** Evaluate the cloud provider's compliance with ISO/IEC 27001, SOC 2, GDPR, or other relevant frameworks.
- Security Controls Review:** Ensure the provider has implemented adequate controls for:
 - Data encryption (at rest and in transit)
 - Identity and access management
 - Backup and disaster recovery
 - Incident response procedures
- Service Level Agreements (SLAs):** SLAs must include:
 - Uptime and performance guarantees
 - Incident notification timeframes
 - Data location and residency assurances

27.2 Acquisition of Cloud Services

- Approval Process:** All cloud acquisitions must be approved by the IT Manager and organization management.

- b. Data Classification: Cloud services must be matched to the classification level of data they will handle (public, internal, confidential, etc.)

27.3 Use of Cloud Services

- a. Access Control: Only authorized users may access cloud services. Access must be role-based and reviewed periodically.
- b. Monitoring: Cloud usage must be monitored for unauthorized access, data leakage, or unusual activities.
- c. Training: Users must be trained on secure cloud usage and the risks associated with storing sensitive data off-premises. (Project Manager will identify the training needs and Trainings will be imparted by CQM Team.
- d. Incident Management: Any security incident involving a cloud service must be reported and managed per the organization's incident response policy.

27.4 Identity & Access Management (IAM)

- a. Enforce RBAC or ABAC to grant the least privilege necessary.
- b. Apply MFA for all access—critical control to prevent credential misuse.
- c. Review access permissions at least every 3 months.
- d. Remove generic/test accounts and enforce account lockout after repeated failures. (We need to updated this period check list and start preparing the report).

27.5 Data Encryption & DLP

- a. Encrypt data at rest and in transit across all providers with cloud-native KMS/HSM services & TLS 1.2 above.
- b. Implement data governance frameworks to address compliance across regions, as applicable.

27.6 Network & Perimeter Security

Apply network segmentation and least-access models.

- a. AWS: VPCs, Security Groups, NACLs, AWS WAF, Shield
- b. Azure: Azure Firewall, Application security groups, Segmentation and routing (As needed)

27.7 Logging & Monitoring

- a. Audit Logs & Sign in Logs maintained for last 30 Days.
- b. Event logs are maintained for the last 90 days.

27.8 Backup, Recovery & Incident Response

Sustain business continuity and secure recovery.

- a. AWS: AWS Backup, S3 Glacier
- b. Azure: Azure Backup + Site Recovery
- c. Requirement: RTO/RPO & DR tests should be aligned with Backup and Restoration Plan (TXPL/FR/IT/007).

27.9 Exit from Cloud Services

- a. Exit Planning: An exit strategy must be defined during the acquisition of new cloud services.
- b. Data Migration: Ensure secure transfer of data to internal systems or another cloud provider.
- c. Data Sanitization: Verify that all organizational data is permanently deleted from the cloud provider's environment.
- d. Access Revocation: Disable all users and administrative access to the cloud service upon exit.
- e. Audit & Verification: Conduct a final security audit or assessment to confirm no data or access remnants exist.

27.10 Responsibility Matrix

Responsibility Area	AWS (IaaS, PaaS, SaaS)	Azure (IaaS, PaaS, SaaS)	Microsoft 365 (SaaS)
Physical Infrastructure	CSP (AWS)	CSP (Microsoft Azure)	CSP (Microsoft)
Network Infrastructure	CSP	CSP	CSP

Hypervisor/Virtualization	CSP	CSP	CSP
Operating System (OS)	Customer (IaaS)CSP (PaaS/SaaS)	Customer (IaaS)CSP (PaaS/SaaS)	CSP
Application Management	Customer (IaaS/PaaS)CSP (SaaS)	Customer (IaaS/PaaS)CSP (SaaS)	CSP
Data Classification & Privacy	Customer	Customer	Customer
Identity & Access Management (IAM)	Shared (Customer manages users, roles, MFA, etc.)	Shared	Shared (Customer manages users, licenses, policies)
Network Security	Shared (Customer manages firewalls, NSGs, etc.)	Shared (similar responsibilities)	CSP (infra); Customer (conditional access, MFA)
Encryption & Key Management	Shared (CSP offers tools; customer manages keys/usage)	Shared	Shared (BitLocker, DLP, etc. controlled by customer)
Data Protection & Backup	Customer responsibility unless using CSP backup tools	Customer responsibility unless using Azure Backup	Customer
Compliance & Governance	Shared (CSP provides compliance tools; customer implements policies)	Shared	Shared (Microsoft provides tools like Compliance Manager)
Endpoint Security	Customer	Customer	Customer (MDE, Intune, etc., optional)
Security Configuration	Customer (configuring VMs, DBs, etc.)	Customer	Shared (CSP secures infra; customer sets policies)

D. Enforcement

A Policy violation will be subject to disciplinary action, which may go so far as employment termination.

E. Responsibilities

Department Heads, HR, System Administrator, IT Manager, End Users, Legal & ISO, CSP (Cloud Service Provider) as applicable.

28. Web Filtering Policy

A. Purpose

This policy defines the configuration and enforcement of web content filtering for users accessing the internet through the organization's network. It aims to ensure appropriate internet use, maintain productivity, and reduce exposure to security threats.

B. Scope

This policy applies to all employees, contractors, and authorized users accessing the internet through the organization's network infrastructure.

C. Policy

28.1 Web Filter Profiles

The following web filter profiles are configured and applied within the network to enforce differentiated access control based on department, risk, or use case:

- a. AI Tools block – Restricts access to unapproved AI tools and platforms.
- b. LDAP_FULLACCESS – Grants full web access to authenticated LDAP users.
- c. Social Sites – Applies restrictions to social networking and media platforms.
- d. Wi-Fi Full Access – Grants unrestricted access over wireless networks.
- e. default – Default policy profile for general internet usage.
- f. Wi-Fi-default – Default profile applied to wireless users with standard restrictions.

28.2 Web Access Categories

Allowed:

- a. Business-related content
- b. Government and public service websites
- c. Educational and training resources
- d. Vendor and partner portals

Blocked:

- a. Malicious sites (phishing, malware, command & control)
- b. Adult content
- c. Gambling and betting
- d. Illegal downloads or torrents
- e. Proxy or anonymizer services
- f. Cryptocurrency mining sites
- g. Hate speech or extremist content
- h. Unauthorized cloud storage or file sharing (e.g., personal Dropbox, WeTransfer)

28.3 Categorized Content Monitoring / Restricted

The following web categories are set to Monitor mode, which logs activity but does not block access:

- a. Web Host Rating
- b. Web-based Email
- c. Web-based Applications
- d. Dynamic Content
- e. Advertisements
- f. Web Analytics
- g. Online Meeting Platforms
- h. Social media (e.g., allowed for Marketing, blocked for others)
- i. Video streaming (e.g., allowed for certain roles)
- j. Shopping and personal email (e.g., Gmail, Outlook.com)

28.4 Exceptions & Whitelisting

- a. As per the business requirements custom filter/Blocking policies defined.
- b. Business critical exceptions may be requested through IT Security.
- c. Requests must be approved by a department head and reviewed by the IT or delegate.
- d. Exceptions will be logged and reviewed periodically.

28.5 User Notifications

Users attempting to access blocked websites will receive a block page with the reason.

28.6 Technical Controls

Web filtering enabled via

- a. Firewall based URL filtering
- b. Endpoint protection software

28.7 Logging & Alerts

Content filtering logs are retained and reviewed by the IT Security team on a periodic basis to detect inappropriate use and maintain compliance.

28.8 Acceptable Usage Policy & User Awareness

All users are expected to adhere to acceptable use standards when accessing the internet. Violations of this policy may result in access restrictions and disciplinary actions. Regular awareness training and mailers related to IT Do's and Don'ts should be delivered.

D. Enforcement

A Policy violation will be subject to disciplinary action, which may go so far as employment termination.

E. Responsibilities

Department Heads, HR, System Administrator and IT Manager.

29. Data Masking Policy

A. Purpose

This policy aims to protect sensitive data in non-production or limited-access environments by using various masking techniques, while maintaining data utility and supporting regulatory compliance.

B. Scope

This policy applies to all full-time permanent, temporary, contractors and other third parties who are generating or handling reports of TestingXperts containing sensitive data (e.g., PII, financial data, client information). This includes reports shared with internal or external stakeholders where data must be protected through irreversible redaction.

C. Policy

29.1 Method:

- a. Sensitive information is permanently redacted in files before distribution.
 - b. Irreversible: Redacted content cannot be restored.
 - c. Manual or semi-automated: Redaction can be done via tools (e.g., Adobe Acrobat, LibreOffice).
 - d. No sensitive data should remain in metadata, comments, or hidden layers.
- Please refer to the annexure Redaction Guidelines for detailed information.

29.2 Process

- a. Identify: Determine which fields in the report contain sensitive information.
- b. Redact: Use approved redaction tools to permanently black out or remove sensitive content.
- c. Validate: Ensure redacted do not contain the original data in metadata or behind the redaction layer.
- d. Archive: Maintain a copy of the redacted version for audit or distribution.
- e. Audit Logs: Keep records of redaction actions where required.

29.3 Security & Compliance

- a. Store original (unredacted) files securely and restrict access.
- b. Ensure redaction tools are correctly configured to remove the underlying text.
- c. Review redaction practices annually or during audits.
- d. Redacted data must comply with data protection laws (e.g., GDPR, HIPAA, PCI-DSS) by ensuring non-disclosure of sensitive details.

D. Enforcement

A Policy violation will be subject to disciplinary action, which may go so far as employment termination.

E. Responsibilities

- a. Data Owners: Identify sensitive fields requiring redaction; approve redaction formats.
- b. IT/Security Teams: Provide standard redaction guidelines, templates, and ensure consistent application across reports.
- c. Report Generators (HR, Finance, Operations, Developers): Apply redaction to sensitive fields before sharing/exporting reports.
- d. Auditors: Verify redacted reports and ensure sensitive content cannot be restored from metadata or document history. Department Head/manager must double-check & ensure sensitive content cannot be restored from metadata or document history before sharing the reports.

30. Data Encryption Policy

A. Purpose

This policy defines requirements for encrypting sensitive data in order to protect confidentiality, integrity, and availability of organizational information, both at rest and in transit.

B. Scope

This policy applies to all the employees, contractors, and third-party users of TestingXperts, all its organizational systems (on-premises, cloud, mobile) and all sensitive data including client information, Employee personal information, financial records, intellectual property, and authentication credentials.

C. Policy

30.1 Encryption Requirements

All data must be classified under one of the following categories:

Sr. No.	Description	Data Classification	Encryption at Rest	Encryption in Transit
1	Strategic backups	Class A	Required (AES-256)	Required (TLS 1.2+)
2	Network Security	Class A	Recommended	Required
3	Asset Inventory	Class C	Recommended	Recommended
4	Incident Management	Class C	Recommended	Recommended

30.2 Encryption at Rest

- a. All sensitive data at rest must be encrypted using approved algorithms (e.g., AES-256).
- b. Encryption must be enforced on:
 - i. Full disk encryption on all computers, mobile devices, servers.
 Windows: BitLocker
 macOS: FileVault
 Mobile: Native OS encryption
 - ii. cloud storage (for example OneDrive, SharePoint, AWS S3, etc.) as applicable
 - iii. Removable media (USB Devices) are blocked by default.

Exception - USB Drives or External Storage media are being used by IT in following scenarios:

- Moving the files between the systems which are not connected to Network
 - Storing the Backup copy of critical Data
 - Creating a installation of recovery drive
- c. Considering the above use cases, all External HDDs and USB drives used by IT must be in NTFS or exFAT format and encrypted with AES-256 standards.

OS Platform	Encryption Tool
-------------	-----------------

Windows	BitLocker
MacOS	FileVault
Linux	LUKS

- d. Encryption password must comply with Password Policy
- e. Encryption key must be stored securely.

30.3 Encryption in Transit

- a. All data in transit over public or untrusted networks must be encrypted using TLS 1.2 or higher.
- b. Encrypted protocols must be used:
 - i. HTTPS (not HTTP)
 - ii. Secure SMTP (TLS), IMAPS, SFTP/FTPS
 - iii. SSL VPNs for remote access
 - iv. Secure IPV4 Tunnels

D. Enforcement

A Policy violation will be subject to disciplinary action, which may go so far as employment termination.

E. Responsibilities

Department Heads, System Administrator and IT Manager.

31. Data Leakage Prevention Policy

A. Purpose

This policy defines the requirements for Data Leakage Prevention (DLP) to prevent unauthorized disclosure, transmission, or loss of sensitive or confidential data, whether data in transit, at rest or in use. The policy aims to prevent unauthorized transmission or exposure of sensitive data and to monitor and control data flows within and outside the organization. This policy ensures compliance with regulatory and contractual data protection obligations and supports the principles of confidentiality, integrity, and availability of information assets.

B. Scope

This policy applies to all employees, contractors and consultants of TestingXperts and to all its organizational assets including laptops, desktops, mobile devices, servers, emails, storage platforms, SaaS applications, cloud services, including all forms of sensitive data (personal data, financial records, intellectual property, and business-critical information).

C. Policy

31.1 Data Classification

- a. All data must be classified according to the organization's Information Classification Document.
- b. DLP rules shall be aligned with classification levels (Public, Internal, Confidential, Restricted).

31.2 DLP Implementation

- a. DLP solutions shall be deployed at the endpoint, email gateway, network, and cloud levels.
- b. All internet-facing channels, including web upload, email, and file-sharing applications, must be monitored for sensitive data exfiltration.

31.3 Control Coverage

Data State	Control Measures
Data in Transit	Monitor outbound emails, file uploads, and cloud sync. Encrypt email content when needed.
Data at Rest	Scan servers, databases, file shares, and endpoints for sensitive data. Take corrective actions (e.g., encrypt, isolate, or delete).
Data in Use	Prevent copy/paste, print, screen capture, and USB transfer of protected data on endpoints.

31.3 Acceptable Use Guidelines

Employees must adhere to the following:

- Do not send sensitive data (e.g., PII, financial info) through unencrypted email or unauthorized tools.
- Avoid saving confidential files on personal devices or cloud services not approved by IT.
- Use secure sharing platforms authorized by the organization.
- Do not bypass or disable DLP controls on managed systems.

31.4 Incident Handling and Reporting

- All suspected DLP violations must be reported immediately via the Incident Reporting Procedure.
- Investigations shall be led by the Information Security Officer in collaboration with relevant stakeholders.
- Root cause analysis will be conducted for confirmed incidents, and appropriate corrective actions will be implemented.

D. Enforcement

A Policy violation will be subject to disciplinary action, which may go so far as employment termination.

E. Responsibilities

Role	Responsibility
Information Security Officer	Define DLP policy, review violations, and ensure compliance.
IT Team	Deploy and maintain DLP solutions, apply updates, and ensure system integrity.
Data Owners	Classify and manage the lifecycle of sensitive data.
Employees/Users	Comply with the DLP policy, avoid sharing sensitive data, and report suspicious activities.